Compliance Sentinel

Compliance audit report

shopwise-demo

Organization	Demo Legal Team
Repository	/Users/princhal/Desktop/Week5 Deliverable/demo-target-repo
Commit	`workdir-0cebab8690f4`
Run ID	`558dc763-3f29-4652-9e1f-2a14a2652770`
Trigger	manual by cli
Generated	2026-10-10 17:02 UTC
Analysis engine	offline-heuristic
Manifest SHA-256	`380d2c98364ade90efff246afcc135edc24e11911ac8633dcb42c1da31775c9`

Executive summary

2	14	3	4
Critical violations	High	Medium	Need human review

The audit compared commit `workdir-0ceb` of **shopwise-demo** against 27 code-checkable obligations from 3 regulatory documents. It found **19** violations and **4** items that need a human decision.

Most frequent issue	Violations
Personal data written to logs	4
Unencrypted data in transit	3
Unencrypted personal data at rest	3
Weak or plaintext password storage	2
Hardcoded credentials	2
Personal data exposed without access control	1

Scope

Regulation	Document	Version	Retrieved
CCPA	California Consumer Privacy Act, Civil Code sections 1798.100 and 1798.105, selected subdivisions https://leginfo.legislature.ca.gov/faces/codes_displayText.xhtml?division=3.&part=4.&lawCode=CIV&title=1.81.5	v1	2026-10-10
GDPR	Regulation (EU) 2016/679 (General Data Protection Regulation), selected articles https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32016R0679	v1	2026-10-10
HIPAA	45 CFR 164.312 Technical safeguards, selected paragraphs https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.312	v1	2026-10-10

Findings overview

#	Severity	Status	Issue	Location	Citation
1	CRITICAL	violation	Weak or plaintext password storage	`app/auth.py:12`	CCPA § 1798.100(e), GDPR Art. 32(1), GDPR Art. 5(1)(f)

2	CRITICAL	violation	Weak or plaintext password storage	`app/auth.py:20`	CCPA § 1798.100(e), GDPR Art. 32(1), GDPR Art. 5(1)(f)
3	HIGH	violation	Hardcoded credentials	`.env:3`	CCPA § 1798.100(e), GDPR Art. 32(1), GDPR Art. 5(1)(f)
4	HIGH	violation	Personal data written to logs	`app/auth.py:27`	GDPR Art. 32(1), GDPR Art. 5(1)(c), GDPR Art. 5(1)(f)
5	HIGH	violation	Unencrypted data in transit	`app/clinic.py:3`	GDPR Art. 32(1), HIPAA § 164.312(a)(2)(iv), HIPAA § 164.312(e)(1)
6	HIGH	violation	Hardcoded credentials	`app/config.py:6`	CCPA § 1798.100(e), GDPR Art. 32(1), GDPR Art. 5(1)(f)
7	HIGH	violation	Unencrypted data in transit	`app/config.py:9`	GDPR Art. 32(1), HIPAA § 164.312(a)(2)(iv), HIPAA § 164.312(e)(1)
8	HIGH	violation	Personal data written to logs	`app/export.py:11`	GDPR Art. 32(1), GDPR Art. 5(1)(c), GDPR Art. 5(1)(f)
9	HIGH	violation	Unencrypted personal data at rest	`app/models.py:16`	GDPR Art. 32(1), HIPAA § 164.312(a)(2)(iv)
10	HIGH	violation	Unencrypted personal data at rest	`app/models.py:26`	GDPR Art. 32(1), HIPAA § 164.312(a)(2)(iv)
11	HIGH	violation	Unencrypted personal data at rest	`app/models.py:35`	GDPR Art. 32(1), HIPAA § 164.312(a)(2)(iv)
12	HIGH	violation	Unencrypted data in transit	`app/routes/orders.py:18`	GDPR Art. 32(1), HIPAA § 164.312(a)(2)(iv), HIPAA § 164.312(e)(1)
13	HIGH	violation	Personal data exposed without access control	`app/routes/users.py:13`	CCPA § 1798.100(e), GDPR Art. 5(1)(f), HIPAA § 164.312(a)(1)
14	HIGH	violation	Personal data written to logs	`app/routes/users.py:29`	GDPR Art. 32(1), GDPR Art. 5(1)(c), GDPR Art. 5(1)(f)
15	HIGH	violation	Right to erasure not supported	`app/routes/users.py:36`	CCPA § 1798.105(a), CCPA § 1798.105(c)(1), GDPR Art. 17(1)
16	HIGH	violation	Personal data written to logs	`web/static/track.js:2`	GDPR Art. 32(1), GDPR Art. 5(1)(c), GDPR Art. 5(1)(f)
17	MEDIUM	violation	Personal data kept longer than necessary	`app/config.py:15`	CCPA § 1798.100(a)(3), GDPR Art. 5(1)(e)
18	MEDIUM	violation	Processing without recorded consent	`app/marketing.py:7`	GDPR Art. 7(1)
19	MEDIUM	violation	More personal data processed than needed	`app/routes/users.py:16`	GDPR Art. 25(2), GDPR Art. 5(1)(c)
20	HIGH	needs review	No breach notification process	`app/models.py:1`	GDPR Art. 33(1)

21	HIGH	needs review	Unencrypted personal data at rest	`app/storage.py:9`	GDPR Art. 32(1), HIPAA § 164.312(a)(2)(iv)
22	MEDIUM	needs review	Transfer of personal data outside the EU	`app/config.py:13`	GDPR Art. 44
23	MEDIUM	needs review	More personal data processed than needed	`app/routes/orders.py:12`	GDPR Art. 25(2), GDPR Art. 5(1)(c)

Detailed findings

1. CRITICAL Weak or plaintext password storage

Violation · confidence 90% · detected by PWD001 · `app/auth.py` lines 12–12

```
10 |
11 | def legacy_password_digest(password: str) -> str:
12 |     return hashlib.md5(password.encode()).hexdigest()
13 |
14 |
```

Static check PWD001: Passwords are hashed with a fast, broken algorithm (MD5/SHA-1). This relates to CCPA § 1798.100(e), which requires the password storage duty to be met.

> **CCPA § 1798.100(e)**: “A business that collects a consumer's personal information shall implement reasonable security procedures and practices appropriate to the nature of the personal information to protect the personal information from unauthorized or illegal access, destruction, use, modification, or disclosure in accordance with Section 1798.81.5.”
> Source: https://leginfo.legislature.ca.gov/faces/codes_displayText.xhtml?division=3.&part=4.&lawCode=CIV&title=1.81.5 · retrieved 2026-10-10

> **GDPR Art. 32(1)**: “Taking into account the state of the art, the costs of implementation and the nature, scope, context and purposes of processing as well as the risk of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organisational measures to ensure a level of security appropriate to the risk, including inter alia as...”
> Source: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32016R0679 · retrieved 2026-10-10

> **GDPR Art. 5(1)(f)**: “Personal data shall be: processed in a manner that ensures appropriate security of the personal data, including protection against unauthorised or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organisational measures ('integrity and confidentiality').”
> Source: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32016R0679 · retrieved 2026-10-10

2. CRITICAL Weak or plaintext password storage

Violation · confidence 80% · detected by PWD002 · `app/auth.py` lines 20–20

```
18 |
19 | def register(db, payload):
20 |     user = User(email=payload.email, password=payload.password)
21 |     db.add(user)
22 |     db.commit()
```

Static check PWD002: A password from user input is stored without hashing. This relates to CCPA § 1798.100(e), which requires the password storage duty to be met.

> **CCPA § 1798.100(e)**: “A business that collects a consumer's personal information shall implement reasonable security procedures and practices appropriate to the nature of the personal information to protect the personal information from unauthorized or illegal access, destruction, use, modification, or disclosure in accordance with Section 1798.81.5.”
> Source: https://leginfo.legislature.ca.gov/faces/codes_displayText.xhtml?division=3.&part=4.&lawCode=CIV&title=1.81.5 · retrieved 2026-10-10

> **GDPR Art. 32(1)**: “Taking into account the state of the art, the costs of implementation and the nature, scope, context and purposes of processing as well as the risk of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organisational measures to ensure a level of security appropriate to the risk, including inter alia as...”
> Source: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32016R0679 · retrieved 2026-10-10

> **GDPR Art. 5(1)(f)**: “Personal data shall be: processed in a manner that ensures appropriate security of the personal data, including protection against unauthorised or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organisational measures ('integrity and confidentiality').”
> Source: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32016R0679 · retrieved 2026-10-10

3. HIGH Hardcoded credentials

Violation · confidence 75% · detected by SEC002 · `.env` lines 3–3

```
1 | DEBUG=true
2 | SMTP_HOST=smtp.shopwise.test
3 | SMTP_PASSWORD=Sup3rS3cretMailPass
```

Static check SEC002: A secret value is committed in an environment file. This relates to CCPA § 1798.100(e), which requires the secrets management duty to be met.

> **CCPA § 1798.100(e)**: “A business that collects a consumer's personal information shall implement reasonable security procedures and practices appropriate to the nature of the personal information to protect the personal information from unauthorized or illegal access, destruction, use, modification, or disclosure in accordance with Section 1798.81.5.”
> Source: https://leginfo.legislature.ca.gov/faces/codes_displayText.xhtml?division=3.&part=4.&lawCode=CIV&title=1.81.5 · retrieved 2026-10-10

> **GDPR Art. 32(1)**: “Taking into account the state of the art, the costs of implementation and the nature, scope, context and purposes of processing as well as the risk of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organisational measures to ensure a level of security appropriate to the risk, including inter alia as...”
> Source: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32016R0679 · retrieved 2026-10-10

> **GDPR Art. 5(1)(f)**: “Personal data shall be: processed in a manner that ensures appropriate security of the personal data, including protection against unauthorised or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organisational measures ('integrity and confidentiality').”
> Source: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32016R0679 · retrieved 2026-10-10

4. HIGH Personal data written to logs

Violation · confidence 85% · detected by PII001 · `app/auth.py` lines 27–27

```
25 |
26 | def login(db, email: str, password: str):
27 |     logger.info(f"Login attempt for {email} with password {password}")
28 |     user = db.query(User).filter_by(email=email).first()
29 |     if user and bcrypt.checkpw(password.encode(), user.password):
```

Static check PII001: Personal data is written to application logs. This relates to GDPR Art. 32(1), which requires the pii logging duty to be met.

> **GDPR Art. 32(1)**: “Taking into account the state of the art, the costs of implementation and the nature, scope, context and purposes of processing as well as the risk of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organisational measures to ensure a level of security appropriate to the risk, including inter alia as...”
> Source: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32016R0679 · retrieved 2026-10-10

> **GDPR Art. 5(1)(c)**: “Personal data shall be: adequate, relevant and limited to what is necessary in relation to the purposes for which they are processed ('data minimisation');”
> Source: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32016R0679 · retrieved 2026-10-10

> **GDPR Art. 5(1)(f)**: “Personal data shall be: processed in a manner that ensures appropriate security of the personal data, including protection against unauthorised or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organisational measures ('integrity and confidentiality').”
> Source: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32016R0679 · retrieved 2026-10-10

5. HIGH Unencrypted data in transit

Violation · confidence 80% · detected by TLS001 · `app/clinic.py` lines 3–3

```
1 | import httpx
2 |
3 | LAB_API = "http://lab-results.medlink.org/api"
4 | LAB_API_SECURE = "https://lab-results.medlink.org/api"
5 |
```

Static check TLS001: Data is sent over plain HTTP instead of HTTPS. This relates to GDPR Art. 32(1), which requires the encryption in transit duty to be met.

> **GDPR Art. 32(1)**: “Taking into account the state of the art, the costs of implementation and the nature, scope, context and purposes of processing as well as the risk of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organisational measures to ensure a level of security appropriate to the risk, including inter alia as...”
> Source: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32016R0679 · retrieved 2026-10-10

> **HIPAA § 164.312(a)(2)(iv)**: “Encryption and decryption (Addressable).”
> Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.312 · retrieved 2026-10-10

> **HIPAA § 164.312(e)(1)**: “A covered entity or business associate must implement technical security measures to guard against unauthorized access to electronic protected health information that is being transmitted over an electronic communications network.”
> Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.312 · retrieved 2026-10-10

6. HIGH Hardcoded credentials

Violation · confidence 90% · detected by SEC001 · `app/config.py` lines 6–6

```
4 | JWT_SECRET = os.environ.get("JWT_SECRET", "")
5 |
6 | PAYMENT_API_KEY = "pk_demo_8f3a9c1e7b2d4f6a90"
7 | API_KEY_PLACEHOLDER = "your-api-key-here-for-docs"
8 |
```

Static check SEC001: A credential is hardcoded in source code. This relates to CCPA § 1798.100(e), which requires the secrets management duty to be met.

> **CCPA § 1798.100(e)**: “A business that collects a consumer's personal information shall implement reasonable security procedures and practices appropriate to the nature of the personal information to protect the personal information from unauthorized or illegal access, destruction, use, modification, or disclosure in accordance with Section 1798.81.5.”
> Source: https://leginfo.legislature.ca.gov/faces/codes_displayText.xhtml?division=3.&part=4.&lawCode=CIV&title=1.81.5 · retrieved 2026-10-10

> **GDPR Art. 32(1)**: “Taking into account the state of the art, the costs of implementation and the nature, scope, context and purposes of processing as well as the risk of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organisational measures to ensure a level of security appropriate to the risk, including inter alia as...”
> Source: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32016R0679 · retrieved 2026-10-10

> **GDPR Art. 5(1)(f)**: “Personal data shall be: processed in a manner that ensures appropriate security of the personal data, including protection against unauthorised or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organisational measures ('integrity and confidentiality').”
> Source: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32016R0679 · retrieved 2026-10-10

7. HIGH Unencrypted data in transit

Violation · confidence 80% · detected by TLS001 · `app/config.py` lines 9–9

```
 7 | API_KEY_PLACEHOLDER = "your-api-key-here-for-docs"
 8 |
 9 | ANALYTICS_URL = "http://collect.shopwise-analytics.io/v1/events"
10 | SVG_NAMESPACE = "http://www.w3.org/2000/svg"
11 |
```

Static check TLS001: Data is sent over plain HTTP instead of HTTPS. This relates to GDPR Art. 32(1), which requires the encryption in transit duty to be met.

> **GDPR Art. 32(1)**: “Taking into account the state of the art, the costs of implementation and the nature, scope, context and purposes of processing as well as the risk of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organisational measures to ensure a level of security appropriate to the risk, including inter alia as...”
> Source: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32016R0679 · retrieved 2026-10-10

> **HIPAA § 164.312(a)(2)(iv)**: “Encryption and decryption (Addressable).”
> Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.312 · retrieved 2026-10-10

> **HIPAA § 164.312(e)(1)**: “A covered entity or business associate must implement technical security measures to guard against unauthorized access to electronic protected health information that is being transmitted over an electronic communications network.”
> Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.312 · retrieved 2026-10-10

8. HIGH Personal data written to logs

Violation · confidence 85% · detected by PII001 · `app/export.py` lines 11–11

```
 9 |     writer = csv.writer(buf)
10 |     for customer in customers:
11 |         print(f"Exporting customer {customer.email} born {customer.date_of_birth}")
12 |         writer.writerow([customer.id, customer.email])
13 |     upload_export("exports/customers.csv", buf.getvalue().encode())
```

Static check PII001: Personal data is written to application logs. This relates to GDPR Art. 32(1), which requires the pii logging duty to be met.

> **GDPR Art. 32(1)**: “Taking into account the state of the art, the costs of implementation and the nature, scope, context and purposes of processing as well as the risk of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organisational measures to ensure a level of security appropriate to the risk, including inter alia as...”
> Source: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32016R0679 · retrieved 2026-10-10

> **GDPR Art. 5(1)(c)**: “Personal data shall be: adequate, relevant and limited to what is necessary in relation to the purposes for which they are processed ('data minimisation');”
> Source: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32016R0679 · retrieved 2026-10-10

> **GDPR Art. 5(1)(f)**: “Personal data shall be: processed in a manner that ensures appropriate security of the personal data, including protection against unauthorised or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organisational measures ('integrity and confidentiality').”
> Source: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32016R0679 · retrieved 2026-10-10

9. HIGH Unencrypted personal data at rest

Violation · confidence 80% · detected by ENC001 · `app/models.py` lines 16–16

```
14 |     phone = Column(String(32))
15 |     password = Column(String(128))
16 |     ssn = Column(String(11))
17 |     passport_number = Column(EncryptedType(String, JWT_SECRET))
18 |     is_deleted = Column(Boolean, default=False)
```

Static check ENC001: A sensitive personal data field is stored as plain text. This relates to GDPR Art. 32(1), which requires the encryption at rest duty to be met.

> **GDPR Art. 32(1)**: “Taking into account the state of the art, the costs of implementation and the nature, scope, context and purposes of processing as well as the risk of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organisational measures to ensure a level of security appropriate to the risk, including inter alia as...”
> Source: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32016R0679 · retrieved 2026-10-10

> **HIPAA § 164.312(a)(2)(iv)**: “Encryption and decryption (Addressable).”
> Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.312 · retrieved 2026-10-10

10. HIGH Unencrypted personal data at rest

Violation · confidence 80% · detected by ENC001 · `app/models.py` lines 26–26

```
24 |     id = Column(Integer, primary_key=True)
25 |     user_id = Column(Integer)
26 |     card_number = Column(String(19))
27 |     expires = Column(String(5))
28 |
```

Static check ENC001: A sensitive personal data field is stored as plain text. This relates to GDPR Art. 32(1), which requires the encryption at rest duty to be met.

> **GDPR Art. 32(1)**: “Taking into account the state of the art, the costs of implementation and the nature, scope, context and purposes of processing as well as the risk of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organisational measures to ensure a level of security appropriate to the risk, including inter alia as...”
> Source: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32016R0679 · retrieved 2026-10-10

> **HIPAA § 164.312(a)(2)(iv)**: “Encryption and decryption (Addressable).”
> Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.312 · retrieved 2026-10-10

11. HIGH Unencrypted personal data at rest

Violation · confidence 80% · detected by ENC001 · `app/models.py` lines 35–35

```
33 |     user_id = Column(Integer)
34 |     starts_at = Column(DateTime)
35 |     diagnosis = Column(Text)
```

Static check ENC001: A sensitive personal data field is stored as plain text. This relates to GDPR Art. 32(1), which requires the encryption at rest duty to be met.

> **GDPR Art. 32(1)**: “Taking into account the state of the art, the costs of implementation and the nature, scope, context and purposes of processing as well as the risk of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organisational measures to ensure a level of security appropriate to the risk, including inter alia as...”
> Source: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32016R0679 · retrieved 2026-10-10

> **HIPAA § 164.312(a)(2)(iv)**: “Encryption and decryption (Addressable).”
> Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.312 · retrieved 2026-10-10

12. HIGH Unencrypted data in transit

Violation · confidence 90% · detected by TLS002 · `app/routes/orders.py` lines 18–18

```
   16 |
   17 | def send_to_fulfilment(order: dict) -> None:
   18 |     requests.post("http://partner-fulfilment.shipco.net/api/orders", json=order,
verify=False)
   19 |
   20 |
```

Static check TLS002: TLS certificate checks or encryption are turned off. This relates to GDPR Art. 32(1), which requires the encryption in transit duty to be met.

> **GDPR Art. 32(1)**: “Taking into account the state of the art, the costs of implementation and the nature, scope, context and purposes of processing as well as the risk of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organisational measures to ensure a level of security appropriate to the risk, including inter alia as...”
> Source: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32016R0679 · retrieved 2026-10-10

> **HIPAA § 164.312(a)(2)(iv)**: “Encryption and decryption (Addressable).”
> Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.312 · retrieved 2026-10-10

> **HIPAA § 164.312(e)(1)**: “A covered entity or business associate must implement technical security measures to guard against unauthorized access to electronic protected health information that is being transmitted over an electronic communications network.”
> Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.312 · retrieved 2026-10-10

13. HIGH Personal data exposed without access control

Violation · confidence 75% · detected by ACC001 · `app/routes/users.py` lines 13–13

```
11 |
12 |
13 | @router.get("/users/{user_id}")
14 | def get_user(user_id: int, db=Depends(get_db)):
15 |     user = db.get(User, user_id)
```

Static check ACC001: An endpoint that handles personal data has no authentication check. This relates to CCPA § 1798.100(e), which requires the access control duty to be met.

> **CCPA § 1798.100(e)**: “A business that collects a consumer's personal information shall implement reasonable security procedures and practices appropriate to the nature of the personal information to protect the personal information from unauthorized or illegal access, destruction, use, modification, or disclosure in accordance with Section 1798.81.5.”
> Source: https://leginfo.legislature.ca.gov/faces/codes_displayText.xhtml?division=3.&part=4.&lawCode=CIV&title=1.81.5 · retrieved 2026-10-10

> **GDPR Art. 5(1)(f)**: “Personal data shall be: processed in a manner that ensures appropriate security of the personal data, including protection against unauthorised or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organisational measures ('integrity and confidentiality').”
> Source: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32016R0679 · retrieved 2026-10-10

> **HIPAA § 164.312(a)(1)**: “A covered entity or business associate must implement technical policies and procedures for electronic information systems that maintain electronic protected health information to allow access only to those persons or software programs that have been granted access rights.”
> Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.312 · retrieved 2026-10-10

14. HIGH Personal data written to logs

Violation · confidence 85% · detected by PII001 · `app/routes/users.py` lines 29–29

```
27 |     db.add(user)
28 |     db.commit()
29 |     logger.debug("Created user %s phone=%s", user.email, user.phone)
30 |     logger.info("User %s created", redact(user.email))
31 |     return {"id": user.id}
```

Static check PII001: Personal data is written to application logs. This relates to GDPR Art. 32(1), which requires the pii logging duty to be met.

> **GDPR Art. 32(1)**: “Taking into account the state of the art, the costs of implementation and the nature, scope, context and purposes of processing as well as the risk of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organisational measures to ensure a level of security appropriate to the risk, including inter alia as...”
> Source: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32016R0679 · retrieved 2026-10-10

> **GDPR Art. 5(1)(c)**: “Personal data shall be: adequate, relevant and limited to what is necessary in relation to the purposes for which they are processed ('data minimisation');”
> Source: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32016R0679 · retrieved 2026-10-10

> **GDPR Art. 5(1)(f)**: “Personal data shall be: processed in a manner that ensures appropriate security of the personal data, including protection against unauthorised or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organisational measures ('integrity and confidentiality').”
> Source: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32016R0679 · retrieved 2026-10-10

15. HIGH Right to erasure not supported

Violation · confidence 80% · detected by DEL001 · `app/routes/users.py` lines 36–36

```
34 | @router.delete("/me")
35 | def delete_account(current_user=Depends(get_current_user), db=Depends(get_db)):
36 |     current_user.is_deleted = True
37 |     db.commit()
38 |     return {"status": "deleted"}
```

Static check DEL001: Delete requests only flag the record; personal data is never erased. This relates to CCPA § 1798.105(a), which requires the data deletion duty to be met.

> **CCPA § 1798.105(a)**: “A consumer shall have the right to request that a business delete any personal information about the consumer which the business has collected from the consumer.”
> Source: https://leginfo.legislature.ca.gov/faces/codes_displayText.xhtml?division=3.&part=4.&lawCode=CIV&title=1.81.5 · retrieved 2026-10-10

> **CCPA § 1798.105(c)(1)**: “A business that receives a verifiable consumer request from a consumer to delete the consumer's personal information pursuant to subdivision (a) of this section shall delete the consumer's personal information from its records, notify any service providers or contractors to delete the consumer's personal information from their records.”
> Source: https://leginfo.legislature.ca.gov/faces/codes_displayText.xhtml?division=3.&part=4.&lawCode=CIV&title=1.81.5 · retrieved 2026-10-10

> **GDPR Art. 17(1)**: “The data subject shall have the right to obtain from the controller the erasure of personal data concerning him or her without undue delay and the controller shall have the obligation to erase personal data without undue delay where one of the following grounds applies: (a) the personal data are no longer necessary in relation to the purposes for which they were collected or otherwise processed;”
> Source: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32016R0679 · retrieved 2026-10-10

16. HIGH Personal data written to logs

Violation · confidence 85% · detected by PII001 · `web/static/track.js` lines 2–2

```
1 | export function onCheckout(user, orderId) {
2 |   console.log("checkout", user.email, user.card_number);
3 |   console.log("checkout complete", orderId);
4 | }
```

Static check PII001: Personal data is written to application logs. This relates to GDPR Art. 32(1), which requires the pii logging duty to be met.

> **GDPR Art. 32(1)**: “Taking into account the state of the art, the costs of implementation and the nature, scope, context and purposes of processing as well as the risk of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organisational measures to ensure a level of security appropriate to the risk, including inter alia as...”
> Source: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32016R0679 · retrieved 2026-10-10

> **GDPR Art. 5(1)(c)**: “Personal data shall be: adequate, relevant and limited to what is necessary in relation to the purposes for which they are processed ('data minimisation');”
> Source: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32016R0679 · retrieved 2026-10-10

> **GDPR Art. 5(1)(f)**: “Personal data shall be: processed in a manner that ensures appropriate security of the personal data, including protection against unauthorised or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organisational measures ('integrity and confidentiality').”
> Source: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32016R0679 · retrieved 2026-10-10

17. MEDIUM Personal data kept longer than necessary

Violation · confidence 80% · detected by RET001 · `app/config.py` lines 15–15

```
13 | EXPORT_REGION = "us-east-1"
14 |
15 | CUSTOMER_DATA_RETENTION_DAYS = None
16 | SESSION_TIMEOUT_MINUTES = 30
```

Static check RET001: Personal data is configured to be kept indefinitely. This relates to CCPA § 1798.100(a)(3), which requires the data retention duty to be met.

> **CCPA § 1798.100(a)(3)**: “A business shall not retain a consumer's personal information or sensitive personal information for each disclosed purpose for which the personal information was collected for longer than is reasonably necessary for that disclosed purpose.”
> Source: https://leginfo.legislature.ca.gov/faces/codes_displayText.xhtml?division=3.&part=4.&lawCode=CIV&title=1.81.5 · retrieved 2026-10-10

> **GDPR Art. 5(1)(e)**: “Personal data shall be: kept in a form which permits identification of data subjects for no longer than is necessary for the purposes for which the personal data are processed ('storage limitation');”
> Source: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32016R0679 · retrieved 2026-10-10

18. MEDIUM Processing without recorded consent

Violation · confidence 75% · detected by CON001 · `app/marketing.py` lines 7–7

```
5 |
6 | def on_signup(user) -> None:
7 |     analytics.track(user.id, "signup", {"email": user.email, "phone": user.phone})
8 |
9 |
```

Static check CON001: Data is sent for tracking or marketing without checking the user's consent. This relates to GDPR Art. 7(1), which requires the consent duty to be met.

> **GDPR Art. 7(1)**: “Where processing is based on consent, the controller shall be able to demonstrate that the data subject has consented to processing of his or her personal data.”
> Source: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32016R0679 · retrieved 2026-10-10

19. MEDIUM More personal data processed than needed

Violation · confidence 75% · detected by MIN002 · `app/routes/users.py` lines 16–16

```
14 | def get_user(user_id: int, db=Depends(get_db)):
15 |     user = db.get(User, user_id)
16 |     return user.to_dict()
17 |
18 |
```

Static check MIN002: A full personal data record is returned, including fields the caller does not need. This relates to GDPR Art. 25(2), which requires the data minimization duty to be met.

> **GDPR Art. 25(2)**: “The controller shall implement appropriate technical and organisational measures for ensuring that, by default, only personal data which are necessary for each specific purpose of the processing are processed.”
> Source: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32016R0679 · retrieved 2026-10-10

> **GDPR Art. 5(1)(c)**: “Personal data shall be: adequate, relevant and limited to what is necessary in relation to the purposes for which they are processed ('data minimisation');”
> Source: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32016R0679 · retrieved 2026-10-10

20. HIGH No breach notification process

Needs review · confidence 55% · detected by BRN001 · `app/models.py` lines 1–1

```
1 | from sqlalchemy import Boolean, Column, DateTime, Integer, String, Text
2 | from sqlalchemy.orm import declarative_base
3 | from sqlalchemy_utils import EncryptedType
```

Static check BRN001: No incident or breach notification process was found in the repository. This relates to GDPR Art. 33(1), which requires the breach notification duty to be met.

> **GDPR Art. 33(1)**: “In the case of a personal data breach, the controller shall without undue delay and, where feasible, not later than 72 hours after having become aware of it, notify the personal data breach to the supervisory authority competent in accordance with Article 55, unless the personal data breach is unlikely to result in a risk to the rights and freedoms of natural persons.”
> Source: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32016R0679 · retrieved 2026-10-10

21. HIGH Unencrypted personal data at rest

Needs review · confidence 70% · detected by ENC002 · `app/storage.py` lines 9–9

```
 7 |
 8 | def upload_export(key: str, data: bytes) -> None:
 9 |     s3.put_object(Bucket=EXPORT_BUCKET, Key=key, Body=data)
10 |
11 |
```

Static check ENC002: Object written to storage without server-side encryption. This relates to GDPR Art. 32(1), which requires the encryption at rest duty to be met.

> **GDPR Art. 32(1)**: “Taking into account the state of the art, the costs of implementation and the nature, scope, context and purposes of processing as well as the risk of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organisational measures to ensure a level of security appropriate to the risk, including inter alia as...”
> Source: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32016R0679 · retrieved 2026-10-10

> **HIPAA § 164.312(a)(2)(iv)**: “Encryption and decryption (Addressable).”
> Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.312 · retrieved 2026-10-10

22. MEDIUM Transfer of personal data outside the EU

Needs review · confidence 60% · detected by XFR001 · `app/config.py` lines 13–13

```
11 |
12 | EXPORT_BUCKET = "shopwise-customer-exports"
13 | EXPORT_REGION = "us-east-1"
14 |
15 | CUSTOMER_DATA_RETENTION_DAYS = None
```

Static check XFR001: Personal data may be stored in a region outside the EU. This relates to GDPR Art. 44, which requires the cross border transfer duty to be met.

> **GDPR Art. 44**: “Any transfer of personal data which are undergoing processing or are intended for processing after transfer to a third country or to an international organisation shall take place only if, subject to the other provisions of this Regulation, the conditions laid down in this Chapter are complied with by the controller and processor.”
> Source: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32016R0679 · retrieved 2026-10-10

23. MEDIUM More personal data processed than needed

Needs review · confidence 70% · detected by MIN001 · `app/routes/orders.py` lines 12–12

```
   10 | def order_customer(order_id: int, db=Depends(get_db),
current_user=Depends(get_current_user)):
   11 |     cur = db.connection().connection.cursor()
   12 |     cur.execute("SELECT * FROM customers WHERE id = (SELECT customer_id FROM orders WHERE
id = %s)",
   13 |                 (order_id,))
   14 |     return cur.fetchone()
```

Static check MIN001: Every column of a personal data table is selected, not just the needed ones. This relates to GDPR Art. 25(2), which requires the data minimization duty to be met.

> **GDPR Art. 25(2)**: “The controller shall implement appropriate technical and organisational measures for ensuring that, by default, only personal data which are necessary for each specific purpose of the processing are processed.”
> Source: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32016R0679 · retrieved 2026-10-10

> **GDPR Art. 5(1)(c)**: “Personal data shall be: adequate, relevant and limited to what is necessary in relation to the purposes for which they are processed ('data minimisation');”
> Source: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32016R0679 · retrieved 2026-10-10

Appendix B: method

Regulatory texts were fetched from their official sources, split into one chunk per article paragraph, and turned into structured obligations. Each obligation has a category that maps to static checks. For every category, the agent combined static check hits with hybrid code search, assessed each piece of evidence against the obligation, and sent every violation through a second review. Findings below the confidence threshold are marked for human review. Code locations always come from the repository itself, never from model output.

This report supports a legal and engineering review. It is not legal advice. Bundled regulation excerpts used in demos must be checked against the official texts.

Approval

Approved by **Demo Auditor** on 2026-10-10 17:02 UTC in Compliance Sentinel.

_____

Signature